

GitLab Internal Acceptable Use Policy

Purpose

This policy specifies requirements related to the use of GitLab computing resources and data assets by GitLab Team Members so as to protect our customers, Team Members, contractors, company, and other partners from harm caused by both deliberate and inadvertent misuse. Our intention in publishing this policy is to outline information security guidelines intended to protect GitLab assets.

It is the responsibility of every member of our Community to interact with GitLab computing resources and data in a secure manner and to that end we provide the following acceptable use standards related to computing resources, company and customer data, mobile and tablet devices, and removable and external media storage devices.

Scope

This policy applies to all GitLab Team Members, contractors, advisors, and contracted parties interacting with GitLab computing resources and accessing company or customer data.

Roles & Responsibilities

Role	Responsibility
-----	-----
GitLab Team Members	Responsible for following the requirements in this procedure
Security, Legal and PeopleOps	Responsible for implementing and executing this procedure
Security, Legal and PeopleOps (Code Owners)	Responsible for approving significant changes and exceptions to this procedure

Procedure

Acceptable Use and Security Requirements of Computing Resources at GitLab

GitLab-managed assets are provided to conduct GitLab business, with consideration given for limited personal use subject to any conflicting statements contained in any individual employment contracts or agreements. Our company uses global electronic communications and resources as routine parts of our business activities. Personal and professional use of GitLab-managed assets are subject to security monitoring and protection, unless prohibited under the local laws of a respective Team Member's jurisdiction. It is essential that electronic resources used to perform company business are protected to ensure that these resources are accessible for business purposes and operated in a cost-effective manner, that our company's reputation is protected, and that we minimize the potential for legal risk.

Those receiving GitLab-provided assets are responsible for exercising good judgment when using GitLab-managed computers and accessing GitLab-managed data.

As per the onboarding issue procedures outlined in our handbook, evidence of device encryption and device serial number must be provided to IT Ops prior to the completion of onboarding period.

We are currently using Jamf as our endpoint management solution for Mac laptops. All macOS laptops procured by GitLab will come configured with Jamf. GitLab Team Members procuring and

expensing Mac Laptops will require Jamf to be installed as part of their Day 1 Security tasks. Upon their discretion, CorpSec may install additional security tools via Jamf.

We are currently using Fleet as our endpoint management solution for Linux laptops. GitLab Team Members using a Linux laptop must enroll their device in Fleet as part of their Day 1 Security tasks. Once a device is enrolled, Fleet automatically installs and continuously enforces the required security tooling, including Endpoint Detection and Response (EDR). See the Linux Desktop OS page for the full list of Linux endpoint requirements. Upon their discretion, CorpSec may install additional security tools via Fleet.

GitLab issued assets are company property and must be treated with care and respect. If applying stickers to company assets:

- Ensure all content is professional and appropriate for a workplace environment
- Do not apply stickers that could damage the device or interfere with its operation
- Do not cover ventilation ports, fans, or other functional elements
- Do not apply anything to the screen or areas that could obstruct the screen when closed

Security and Proprietary Information

All GitLab data is categorized and must be handled in accordance with the Data Classification Standard. All computing assets that connect to any part of the GitLab network, or 3rd party services that are used by GitLab, must comply with the applicable standards.

Customer Support Data Exception

While access to RED data on non-approved systems is generally prohibited as outlined in the GitLab Data Classification Standard, a limited exception exists for team members providing technical support to customers.

Team members are permitted to migrate RED classified customer data to their GitLab-managed laptops solely for the purposes of providing customer support services. This exception is subject to the following requirements:

- Data migration is only permitted for active customer support cases
- Customer data must be promptly deleted immediately upon resolution of the support case
- On macOS, this must include emptying the Trash, or using the rm command-line utility (which skips the Trash).
- All data handling activities must be logged and documented within the ZenDesk ticket

Important: Migrating customer data to local machines is prohibited for all other business operations outside of providing customer support. Team members requiring similar data access for other purposes must follow the Security and Technology Policy Exception Process or contact the Security or Privacy teams with questions before proceeding.

Open source libraries

Open Source libraries are allowed under this policy if its use complies with the pre-approved or approval requirements captured in the Product Legal Handbook.

Freeware, Browser Extensions, Add-ons, and Plugins

Individual Use Software (freeware, add-ons and plugins) is permitted, with the exception of unauthorized Google Workspace Integrations and Chrome Extensions. Individual Use Software is subject to retroactive removal at any time by IT, Legal and Security when it is deemed unsafe or

insecure.

Authorized Google Workspace Integrations and other approved Individual Use Software can be found on the Pre-Approved Individual-Use Software list and are permitted for use subject to any "Notes and Restrictions" for each respective Pre-Approved software offering.

To request approval for new Individual Use Software, please follow the Individual Use Software request process.

In order to abide by the SAFE Framework, to preempt third party processing of company data under permissive individual use licensing terms, or to prevent Team Member misuse of certain Third Party Software features, IT, Legal, Privacy and Security will generally err on the side of disallowing exceptions to enterprise level software, particularly if there is an enterprise option already in our Tech Stack Applications that achieves a similar purpose.

Unacceptable Use

Team Members and contractors may not use GitLab-managed resources for activities that are illegal or prohibited under applicable law, no matter the circumstances.

Security requirements for GitLab production and corporate environments and on GitLab-managed assets must not be disabled without security approval via the Information Security Policy Exception Management Process.

Unacceptable System and Network Activities

Prohibited system and network activities include, but are not limited to, the following:

- Violations of the rights of any person or company protected by copyright, trade secret, patent or other intellectual property, or similar laws or regulations.
- Unauthorized copying, distribution, or use of copyrighted material.
- Exporting software, technical information, encryption software, or technology in violation of international or national export control laws.
- Intentional introduction of malicious programs into GitLab networks or any GitLab-managed computing device.
- Intentional misuse of any GitLab-managed computing device or GitLab networks (e.g. for cryptocurrency mining, botnet control, etc.).
- Sharing your credentials for any GitLab-managed computer or 3rd party service that GitLab uses with others, or allowing use of your account or a GitLab-managed computer by others. This prohibition does not apply to single-sign-on or similar technologies, the use of which is approved.
- Using a GitLab computing asset to procure or transmit material that is in violation of sexual harassment policies or that creates a hostile workplace.
- Making fraudulent offers of products, items, or services originating from any GitLab account.
- Intentionally accessing data or logging into a computer or account that the Team Member or contractor is not authorized to access, or disrupting network communication, computer processing, or access.
- Executing any form of network monitoring that intercepts data not intended for the Team Member's or contractor's computer, except when troubleshooting networking issues for the benefit of GitLab.
- Attempting to bypass, modify, disable or tamper with security controls or logs.
- Attempting to uninstall security controls without prior approval from a Security manager
- Circumventing user authentication or security of any computer host, network, or account used by GitLab.

- Tunneling between network segments or security zones (e.g., gprd, gstg, ops, ci, ngrok), except when troubleshooting issues for the benefit of GitLab.
- Given the potential sensitivity of the data contained in screenshot images, the use of tools that capture and share screenshots to hosted sites online is prohibited without the explicit approval of the Security and Legal Departments. Screenshots should be stored locally or within Google drive folders associated with your GitLab.com account. Access to these drives and files should be managed in accordance with our Access Management policy, and handled according to our Data Classification Standard. Tools such as Lightshot, where upload functionality cannot be disabled and could result in inadvertent uploads, should not be used.
- The use of high risk remote administration tools, such as TeamViewer and AnyDesk, which are commonly used by attackers to gain and remotely control systems.
- Tools that emulate another operating system or create compatibility layers such as WINE
- The use of torrent or other P2P software on GitLab computing assets.

Unacceptable Email and Communications Activities

Forwarding of confidential business emails or documents to personal external email addresses is prohibited. Automated forwarding of emails from a team member account is also prohibited.

> Note: GitLab may retrieve messages from archives and servers without prior notice if GitLab has sufficient reason to do so. If deemed necessary, this investigation will be conducted with the knowledge and approval of the Security, People Business Partners, and Legal Departments.

In addition to following the Team Member Social Media Policy, when utilizing social media think about the effects of statements that you make. Keep in mind that these transmissions are permanent and easily transferable, and can affect our company's reputation and relationships with Team Members and customers. When using social media tools like blogs, Facebook, Twitter or wikis, ensure that you do not make comments on behalf of GitLab without proper authorization. Also, you must not disclose our company's confidential or proprietary information about our business, our suppliers, or our customers.

Return of GitLab-Owned Assets

All GitLab-owned computing resources must be returned upon separation from the company. Notwithstanding anything contrary in the Laptop Buy Back Policy or the Offboarding Tasks, Team Members must return any GitLab-Owned Assets -- irrespective of their valuation -- if they are specifically requested to do so either during their tenure with GitLab or upon offboarding. In cases of investigation, misconduct, termination for cause or any violation of GitLab's Code of Business Conduct & Ethics, a team member has no right to retain GitLab-owned computing equipment.

Bring-Your-Own-Device (BYOD)

As a general rule, non-company devices are not permitted to access company assets. While there are some exceptions listed below, access to RED classified data, as defined by the GitLab Data Classification Standard, is still prohibited.

The exceptions are as follows:

Personal Mobile Phone and Tablet Usage

All personal mobile computing devices used to access GitLab-managed data, including but not limited to email and GitLab.com, must be passcode-enabled. 2FA will be enforced by the Security team for all employee and contractor GitLab.com and Google Workspace accounts. Mobile computing best practices dictate that these devices should be running the latest version of the operating system

available, and all new patches applied. For assistance with determining the suitability of your mobile device, please contact the Security Team.

Unable to Use Company Laptop

For new employees who have not received a company laptop, there are exception processes for using non-company devices.

The same exception processes apply in the case of a corporate laptop being unavailable or unusable due to loss, theft or disrepair. See lost or stolen procedures for additional information. You must open a Policy Exception Request. While the exception processes are considered a temporary solution, you still need to make sure the non-company system meets basic configuration standards, and a Microsoft Windows system is still not allowed access under any circumstances.

Do not sign in to any GitLab related accounts using public computers, such as library or hotel kiosks.

Mobile Messaging

All GitLab-related conversations need to take place in Slack. It is strongly recommended that the official Slack application, or Slack web application, are used for mobile messaging. Downloads are available for iOS and Android. While it may be more convenient to use an integrated chat application that puts all of your conversations in one place, the use of these applications can unintentionally lead to work-related conversations crossing platforms, or being sent to external contacts. The use of Slack for all work communications assists with our security and compliance efforts. For example, in the case of an incident response issue, it may be necessary to review a conversation to understand the order in which events occurred, or to provide evidence that the chain of custody has been maintained for forensic evidence during a handoff.

For video calls, and as a back-up to Slack, we prefer Zoom. Zoom chats are an acceptable alternative to Slack when in a video call. If the conversation is interesting to others or may be needed for a retrospective, consider recording the call.

Use of External Media on Company Assets

The use of removable and external storage devices such as USB flash drives and external backup drives on company-managed devices is not allowed and is blocked by default. An exception request may be opened here if there is a business need for the use of an external storage device. Corporate Security will coordinate with requestors to determine the most suitable encryption-enabled device and configure encryption and password protection.

As a reminder, Red Data may not be transmitted from an approved Red data source to any other systems or solutions without first obtaining approval from the Privacy and Security teams. Please refer to GitLab's Data Classification Standard for further details.

Use of file sharing services other than GitLab's Google Drive

Creating an account or using for backup/redundancy purpose a file sharing service other than GitLab's Google Drive is prohibited. For sharing GitLab-related files with those external to GitLab, an exception must be granted. To obtain an exception create an access request outlining the business case, and do not proceed until the exception has been granted.

When creating an account with and using a file sharing service other than Google Drive, Team Members must:

- Where available, use the Sign in with Google single sign-on option using a GitLab Google Workspace account, rather than creating an account using a GitLab (or other provider) email

address and password.

- Only upload files directly to shared folders created by those external to GitLab and do not upload files to the personal area of the file sharing service.
- Remove all files and close the account when the file sharing service is no longer needed.

Lost or Stolen Procedures

GitLab provides a panic@gitlab.com email address and a lost or stolen procedure for team members to use in situations that require an immediate security response. Should a team member lose a device such as a thumb drive, Yubikey, mobile phone, tablet, laptop, etc. that contains their credentials or other GitLab-sensitive data, they should send an email to panic@gitlab.com right away. When the production and security teams receive an email sent to this address it will be handled immediately. Using this address provides an excellent way to limit the damage caused by a loss of one of these devices.

GitLab reserves the right to request documentation of the theft and/or a related police report in the case of a stolen laptop.

Policy Compliance

Compliance with this policy will be verified through various methods, including but not limited to, automated reporting, audits, and feedback to the policy owner.

Any Team Member or contractor found to be in violation of this policy may be subject to disciplinary action, up to and including termination of employment, or contractual agreement.

Consultations

To consult with the Security Team create an issue in the Security Compliance tracker.

Exceptions

Exceptions to this policy must be approved by Security, Legal and PeopleOps Departments.

- Onboarding Issue
- Data Classification Standard
- Asset return procedure
- Lost or stolen asset procedure

References

- GitLab's Community Code of Conduct applies to all members of the GitLab community